

Technische und organisatorische Maßnahmen

Sicherheitskonzept für Kundendaten, Geräte und FieldOps

Version 1.0-2026-07-21 | Stand 21.07.2026

Schutzziel

Vertraulichkeit, Integrität, Verfügbarkeit, Belastbarkeit und nachvollziehbare Löschung der verarbeiteten Daten.

1. Zugang und Authentifizierung

Persönliche Supabase-Benutzerkonten für Kevin Voss und Björn Dicke; E-Mail-OTP/2FA; lokaler sechsstelliger Schnell-PIN nur als Gerätesperre; Sperre nach Fehlversuchen; keine gemeinsamen persönlichen Konten.

2. Berechtigung

Row Level Security in Supabase; keine anonymen Datenzugriffe; Service-Key nur serverseitig; endgültige Löschung, Dokumentdownload und Export nur nach authentifizierter Teamsitzung. Bei späteren Mitarbeitern ist ein rollenbasiertes Modell vor Freischaltung erforderlich.

3. Übertragung und Speicherung

HTTPS/HSTS; private Supabase-Dokumentablage; keine Kundendaten im GitHub-Repository, lokalen Browsercache oder PWA-Service-Worker; keine Kundendaten in URLs; API-Antworten mit no-store.

4. Geräte

Geschäftsgeräte mit Displaysperre, Datenträgerverschlüsselung, automatischen Updates, Fernsperre/Fernlöschung und getrennten Benutzerkonten. Downloads und Papierunterlagen sind nach Zweckende zu löschen beziehungsweise im abschließbaren Schrank aufzubewahren.

5. Eingaben und Datenminimierung

Serverseitige Schema- und Längenprüfung; E-Mail freiwillig; keine Geburts-, Bank-, Zähler-, Ausweis- oder vollständigen Vertragsdaten in FieldOps; Freitext nur sachlich und ohne besondere Kategorien personenbezogener Daten.

6. Protokollierung

Audit-Einträge für Anmeldung, Kundenaufnahme, Unterschrift, Änderung, Export, Dokumentupload, Papierkorb, Wiederherstellung und endgültige Löschung; Protokolle zeitlich begrenzen und bei Personenlöschung minimieren.

7. E-Mail und Push

Unterschiedene PDF nur serverseitig versenden; Absenderdomain beim Versanddienst verifizieren; Gmail als Antwortadresse; Versandstatus dokumentieren. Push-Inhalte auf Sperrbildschirmen grundsätzlich neutral.

8. Sicherung und Wiederherstellung

Automatische verschlüsselte Backups, dokumentierter Standort und Aufbewahrungszyklus; Zugriffe auf wenige Berechtigte beschränken; Wiederherstellung mindestens jährlich testen; gelöschte Daten bei Wiederherstellung erneut aus dem aktiven Bestand entfernen.

9. Vorfälle

Geräteverlust, falscher E-Mail-Versand, unberechtigter Zugriff und veröffentlichte Schlüssel sofort eindämmen; Sitzungen widerrufen, Schlüssel rotieren, Umfang und Risiko dokumentieren und Meldepflichten prüfen.

10. Dienstleister

Vor Produktivbetrieb Datenschutzrollen, AV-Verträge, Unterauftragnehmer, Regionen, Supportzugriffe, Backups und Löschmöglichkeiten für Supabase, Vercel, Resend, Google/Gmail und TeleSon dokumentieren.

11. Wartung

Abhängigkeiten, Sicherheitsheader, RLS-Regeln, Cron-Läufe und Zugriffsrechte regelmäßig prüfen; CI mit Typprüfung, Lint und Produktions-Build; Security-Updates zeitnah einspielen.